

Block 00b — authorized corrective Copilot review receipt

Historical corrective receipt. Third and fourth Copilot reviews followed. See the [fourth-review](#) and [hardening receipt](#) for current status. The evidence below remains frozen to its stated commits.

Status at source generation: the six new findings have scoped code dispositions; **final-head hosted CI and artifact inspection are pending**. Block 00b is not accepted, merged, or released. The corrective review itself returned **Changes recommended**, and no further Copilot request is authorized by this receipt.

Identity and boundary

- PR: [#856](#), base release/715–stack-00–audit–base at 9cb72384fd14b2a688a70d17711a7923941d2290.
- Previous remediation head: 71ce20c7df2f2401b0d605a550e38418fb5f2034; its [exact-head CI](#) passed and its first 20 Copilot findings were individually dispositioned and resolved.
- User-authorized second [Copilot review 5298915862](#) was delivered on that head, with six inline comments and no additional body-only concrete finding. The review's overview describes the intended broad firmware diff. It is **Lite / Changes recommended** (three high, three medium).
- Corrective implementation: 3eb54b36cf703eb8f86e7e86b807cde86274e597 (12 paths, 146 additions / 31 deletions). The documentation-only containing head and final CI run are recorded in the PR and master ledger after qualification. Dependency pins and C-2 bootloader policy remain as recorded in the [first-review remediation report](#).

The existing PR is a broad integration exception; this receipt covers the six newly reported contracts and affected consumers. It does not independently requalify every unchanged path in the original integration replay. A resolved thread is a disposition, not an independent clean review.

Finding dispositions and security contracts

Comment	Disposition and value origin	Observer / phase / allowed result	Forbidden result and test
4089127891	Fixed. Runtime clears sign public key, alias, icon and verified metadata originate in a user-approved signer load. ClearSession, Initialize, flash reinitialization, accepted LoadDevice, reset start and non-dry-run recovery start clear the runtime signer set. Dry-run recovery is not wallet replacement.	Later host metadata calls may use a signer only during the current wallet session, after its load consent.	Trust surviving a session end or flash reopen, or stale alias/metadata reuse. Real ReviewHandlers.SessionEndClearsRuntimeSignerAndAlias and ReopeningFlashClearsRuntimeSigner invoke the FSM/storage paths and inspect the runtime keyring.
4089127918	Fixed. The Windows DLL export and Apple arm64 linker flags use set_property(... APPEND_STRING PROPERTY LINK_FLAGS ...), supported by the declared CMake 3.7.2 baseline. Both former target_link_options calls are removed.	CMake configures supported platform conditions without requiring a newer command.	Rejection of the Windows DLL configure from the unavailable command. Source mechanical check and final macOS CI cover the Apple branch; local complete MinGW configuration is blocked by missing nanopb generator. No Windows runtime qualification is claimed.
4089127945	Fixed. Host EthereumTxMetadata.key_id remains full-width until a range check; only values below METADATA_MAX_KEYS reach the uint8_t consumer.	A valid key selects only its intended slot before a metadata acknowledgment.	256 wrapping to slot 0 or any other out-of-range alias; ReviewHandlers.MetadataKeyIdRefusesNarrowingBeforeAck passes 4, 256 and UINT32_MAX to the actual handler and requires a failure.

Comment	Disposition and value origin	Observer / phase / allowed result	Forbidden result and test
4089127974	Fixed. BIP-85 was already specified in the pinned wire protocol and supplied as source, but could not run. Full firmware now compiles bip85.c, includes the handler, and dispatches GetBip85Mnemonic; shared sensitive display scratch has explicit declarations. Bitcoin-only still excludes this non-BTC addition.	An initialized, PIN-checked user can confirm an on-device child mnemonic, with Success only after pages; the mnemonic never enters a response.	Dormant wire command, incorrect derived words, success after cancellation, or residual display scratch. The real handler regression exercises cancellation and success/page cleanup; an independent Python BIP32/BIP39 oracle for the test mnemonic yields eternal siege creek hand combine grass name balance identify rude ozone truly at index 0. The path and HMAC construction follow BIP-85 . Physical OLED is a later release gate.
4089128007	Fixed by removing the unused public formatter and declaration. The active handler's osmosis_format_amount remains the only amount renderer; it preserves exact integer strings when the denomination's exponent is unknown.	User sees the value used by the active signing confirmation path.	A second, divergent strtoull formatter presented as active safety coverage. Existing Osmosis handler/native tests and final host tests exercise the active path.
4089128031	Fixed. storage_init() recomputes both firmware-too-old and Bitcoin-only locks from the flash buffer opened in this invocation.	A newer unsupported record remains non-destructively locked; a later supported/empty record in the same process is usable.	Old lock inheriting across flash reopen and silently discarding commits. ReviewHandlers.StorageReinitialization RecomputesFirmwareLock seeds a newer record, checks the refusal, reopens a normal buffer, then checks the lock and ability to load a wallet. The earlier newer-format flash-preservation test remains.

Final-run regression correction

CI [35948487332](#) built both variants, ARM, host integration, and the macOS library successfully. The full firmware suite ran 354 tests: 353 passed and one newly added BIP-85 success-path assertion failed. The handler succeeded and wiped display scratch; the test had treated `kkconfirm_drain()` as a count of confirmations when it counts two queued button events per confirmation. Twenty accepted confirmations queue 40 events; four observed screens leave 32. The one-line test correction asserts that exact count. The downstream report gate failed because the native suite failed. This run is failure evidence, not qualification; the follow-up must pass at its own final head.

Executed checks and limits

The focused full-emulator handler run passed **9 of 9 tests** after the initial code changes, including the BIP-85 oracle, session end, full-width key rejection and storage lock regression. A new flash-reopen signer assertion and the BIP-85 success/page-scratch assertion were added afterward; they require final-head CI. The independent Python BIP32/HMAC/BIP39 calculation reproduced the explicit child phrase above without calling firmware code. `actionlint`, formatting and diff-whitespace checks pass.

The local full/BTC Docker matrix could not start after the host disk filled; Docker's metadata database reports a read-only filesystem. Pruning unused Docker build cache was attempted and failed for the same reason. The host MinGW CMake configure reached compiler checks but stopped at the absent nanopb generator before the DLL target; it is not a Windows build pass. Final-head CI must demonstrate full/BTC native tests, host integration, ARM/SRAM, macOS shared library tests, report generation and release gates before these six dispositions are qualified. Earlier CI belongs to the earlier head and cannot qualify this commit.

The one-request-per-corrective-checkpoint limit is exhausted: review [5297484301](#) covered the earlier original candidate and review [5298915862](#) covered `71ce20c7d`. Any later source change makes the second verdict historical. Do not request a third review automatically or relabel either **Changes recommended** verdict as clean. Continue the batch from the canonical main ledger with audit acceptance pending.